ISO/IEC 27018:2019 Attestation — Public Cloud PII Processing

Attestation of conformance

This attests that the controls operated by the service organisation for the processing of personally identifiable information in public cloud have been assessed against ISO/IEC 27018:2019 and found to conform. The assessment was conducted alongside the ISO/IEC 27001:2022 surveillance activity in February 2026 by the same accredited certification body, and covers the same certified scope.

Why this standard, and what it adds

ISO/IEC 27001 establishes the management system. ISO/IEC 27018 layers onto it a specific set of obligations for an organisation acting as a processor of personally identifiable information in public cloud. The obligations that customers most often ask about are the ones addressed below: processing only on documented instruction, restrictions on secondary use, disclosure of sub-processors, notification of law enforcement requests, and return or deletion of data at the end of the relationship.

Processing on documented instruction

The service organisation processes personally identifiable information contained in message content and metadata solely to deliver the contracted service and solely on the documented instruction of the customer, as recorded in the Data Processing Agreement and the tenant's configured policy. There is no use of customer content for marketing, for product analytics, or for the training of machine learning models. Where the organisation is required by law to process outside the customer's instruction, that requirement is recorded and, unless prohibited, communicated to the customer.

Sub-processing and disclosure

Sub-processors are disclosed in a published register that names each entity, the processing it performs, and the country in which that processing occurs. Customers are notified at least thirty days before a new sub-processor begins processing, and may object within that window under the terms of the Data Processing Agreement. Each sub-processor is bound by contractual terms no less protective than those the organisation owes its customers, and is reassessed annually.

Government and law enforcement access

Requests from law enforcement or government for customer content are refused unless the request is legally binding on the organisation. Where a request is legally binding, the organisation seeks to redirect the requester to the customer. Where redirection fails and notification is not legally prohibited, the customer is notified before disclosure so that it may seek relief. The organisation publishes an aggregate transparency figure annually. Because message bodies at rest are encrypted under tenant

key-encryption keys, a tenant holding its own root key material materially constrains what could be disclosed in response to any such request.

Residency and cross-border transfer

Personally identifiable information is processed in the residency zone elected by the tenant at provisioning. Cross-border transfer occurs only where the tenant enables a feature that requires it, or where support access is granted on a per-session, named-approval basis. Transfers out of the European Economic Area rely on the 2021 Standard Contractual Clauses supplemented by a transfer impact assessment; transfers out of the United Kingdom rely on the International Data Transfer Addendum.

Return and deletion

On termination, the customer may export its data through the documented export path for a period of thirty days. After that period, or immediately on written instruction, content is deleted. Deletion is confirmed in writing. Content held in backup images is rendered unrecoverable as those images age out of the retention window, which does not exceed thirty-five days; the confirmation of deletion states this explicitly rather than implying instantaneous erasure everywhere.